

Compte-rendu (Google Skills / GCP) : GSP1124 – Get Started with Security Command Center

Exploration, configuration et remédiation de findings SCC

1 Source, contexte et objectif

Ce document résume le lab **GSP1124** *Get Started with Security Command Center* et explique **commande par commande** (CLI + requêtes dans l'interface SCC) ce que fait chaque instruction. Le lab est donné dans un projet sandbox et vise une prise en main de l'interface, des services (sources), des modules et des findings.

Objectifs du lab :

- Explorer les éléments d'interface de **Security Command Center (SCC)**.
- Configurer SCC au niveau projet (modules Security Health Analytics).
- Analyser des findings, changer leur **state**, utiliser **mute** / règles de mute, et remédier à des risques réseau.

2 Rappels SCC (termes du lab)

- **Finding** : enregistrement produit par SCC décrivant une vulnérabilité ou une menace.
- **Threats** : activités suspectes en cours (ex. service account qui explore ses permissions).
- **Vulnerabilities** : mauvaises configurations / vulnérabilités (ex. ports ouverts, logs désactivés).
- **Services** / **Sources** : modules intégrés de SCC qui génèrent des findings (terminologie interchangeable dans le lab).
- **Security Health Analytics (SHA)** : service SCC orienté *misconfigurations* (IAM excessif, logs désactivés, exposition publique, etc.).
- **State** d'un finding : indique si le problème est actif et requiert attention (**ACTIVE**) ou non (**INACTIVE**).
- **Mute** : permet de masquer des findings jugés bruyants/irrélevants (ponctuel ou dynamique via des règles).

3 Commandes Cloud Shell (gcloud) et explications

(Optionnel) Vérifier le compte authentifié

```
gcloud auth list
```

- Liste les identités connues de **gcloud** dans Cloud Shell.
- Affiche le compte **actif** (marqué avec *).
- Utile pour confirmer que l'on utilise bien le compte temporaire fourni par le lab.

(Commande suggérée) Changer le compte actif

```
gcloud config set account 'ACCOUNT'
```

- Définit quel compte Google est utilisé par défaut par `gcloud`.
- 'ACCOUNT' est à remplacer par l'identifiant affiché dans `gcloud auth list`.

(Optionnel) Vérifier le projet courant

```
gcloud config list project
```

- Affiche le `project` courant dans la configuration `gcloud`.
- Permet de s'assurer qu'on opère sur le bon `PROJECT_ID` (projet sandbox du lab).

Créer un réseau VPC (pour tester les findings et les règles de mute)

```
gcloud compute networks create scc-lab-net --subnet-mode=auto
```

- Crée un réseau **VPC** nommé `scc-lab-net`.
- `--subnet-mode=auto` : crée automatiquement des sous-réseaux (subnets) dans les régions prédéfinies.
- But pédagogique : générer (ou faire réapparaître) des **findings** liés à des pratiques réseau par défaut (ex. Flow Logs désactivés) et vérifier l'effet des **mute rules**.

4 Actions dans l'interface SCC (pas des commandes CLI)

Le lab contient aussi des actions dans la console (Navigation menu → Security → Overview / Findings / Settings). Même si ce ne sont pas des commandes terminal, elles modifient des états (ex. activation de modules, changement de state, création de mute rules).

4.1 Éléments d'interface SCC (repères)

Le lab décrit plusieurs sections de SCC :

Section SCC	Description (résumé)
Overview	Vue synthèse des vulnérabilités par catégorie et sévérité.
Graph Search	Recherche d'assets et findings via des requêtes en langage naturel.
Issues	Risques notables (Premium/Enterprise).
Findings	Liste et gestion des findings (filtre, état, mute, etc.).
Assets	Inventaire des ressources (Cloud Asset Inventory).
Compliance	Indicateurs de conformité (CIS, PCI DSS, NIST 800-53, etc.).
Sources	Services/modules qui détectent (config et activité) et produisent des findings.
Posture Management	Gestion de posture de sécurité via le service dédié.

5 Requêtes (Query editor) SCC et explications

Dans l'onglet **Findings**, SCC propose un *Query editor* (filtre) : ce ne sont pas des commandes shell, mais elles pilotent la sélection/affichage des findings.

Filtrer sur la catégorie Default network

```
category="DEFAULT_NETWORK"
```

- Affiche uniquement les findings de la catégorie `DEFAULT_NETWORK`.
- Utile pour isoler les alertes causées par les ressources créées « par défaut » (réseau VPC par défaut).

Filtrer les findings actifs, non mutés, et liés aux Subnetworks

```
state="ACTIVE" AND NOT mute="MUTED" AND resource.type="google.compute.Subnetwork"
```

- `state="ACTIVE"` : ne garde que les findings encore considérés comme nécessitant attention.
- `NOT mute="MUTED"` : exclut ceux qui ont été masqués (muted).
- `resource.type="google.compute.Subnetwork"` : limite aux findings dont la ressource est un sous-réseau VPC.
- Effet attendu dans le lab : mettre en évidence des misconfigurations des subnets (ex. Private Google Access, Flow Logs).

Revenir à une vue « actifs et non mutés »

```
state="ACTIVE" AND NOT mute="MUTED"
```

- Réinitialise une vue standard : les findings visibles par défaut dans beaucoup de contextes SCC.

Afficher les findings “Flow Logs disabled” (même s’ils sont mutés)

```
category="FLOW_LOGS_DISABLED"
```

- Filtre sur la catégorie de findings indiquant que les **VPC Flow Logs** sont désactivés.
- Point important du lab : même si une règle de mute existe, on peut toujours **retrouver** les findings via requête.

6 Gestion des findings : état (state) et masquage (mute)

6.1 Changer l’état d’un finding (ACTIVE ↔ INACTIVE)

Dans l’UI, l’action *Change active state* permet de passer un finding de **ACTIVE** à **INACTIVE** (ou l’inverse).

- **But** : signaler qu’un problème a été traité (ou au contraire qu’il redevient d’actualité).
- **Effet** : un finding **INACTIVE** peut disparaître des vues par défaut (souvent basées sur **ACTIVE + unmuted**).
- **Note lab** : les findings ne sont pas supprimables manuellement ; SCC peut les purger automatiquement si non rafraîchis sur une longue période (le lab mentionne une durée).

6.2 Muter des findings existants (ponctuel)

Dans l'UI : *Mute options* → *Apply mute override*.

- **But** : masquer immédiatement les findings sélectionnés (ex. bruit en environnement de test).
- **Limite** : n'empêche pas l'apparition de futurs findings similaires.

6.3 Créer une règle de mute dynamique (futur + existant de façon asynchrone)

Dans l'UI : *Mute options* → *Manage mute rules* → *Create mute rule*. Exemple de règle du lab :

- **Mute rule ID** : `mute-flowlogs-findings`
- **Description** : Mute rule for VPC Flow Logs
- **Findings query** : `category="FLOW_LOGS_DISABLED"`
- **But** : masquer automatiquement tous les findings correspondant à la requête à l'avenir.
- **Note** : application asynchrone possible sur les findings déjà présents (délai mentionné dans le lab).

7 Remédiation : corriger deux findings “High” (Open RDP / Open SSH)

Le lab demande de remédier à deux findings haute sévérité :

- **Open RDP port**
- **Open SSH port**

Cause

Des règles firewall du réseau (ex. `default` network) autorisent le trafic entrant RDP/SSH depuis `0.0.0.0/0` (Internet entier).

Fix demandé (dans l'UI Firewall rules)

Pour chaque règle concernée :

- Supprimer la plage source `0.0.0.0/0`.
- Ajouter `35.235.240.0/20` (plage utilisée pour l'accès via **Identity-Aware Proxy** TCP forwarding).
- Sauvegarder, puis rafraîchir SCC : les findings doivent disparaître progressivement (ou ne plus être High).

8 Conclusion

Ce lab introduit SCC en pratique :

- Lecture de tableaux de bord et compréhension des classes de findings (Threats vs Vulnerabilities).
- Configuration au niveau projet : services/sources, modules SHA, et impact des changements.
- Triage : filtres, query editor, state, mute ponctuel et règles de mute.
- Remédiation réseau : réduction d'exposition (RDP/SSH) via restriction des plages source.